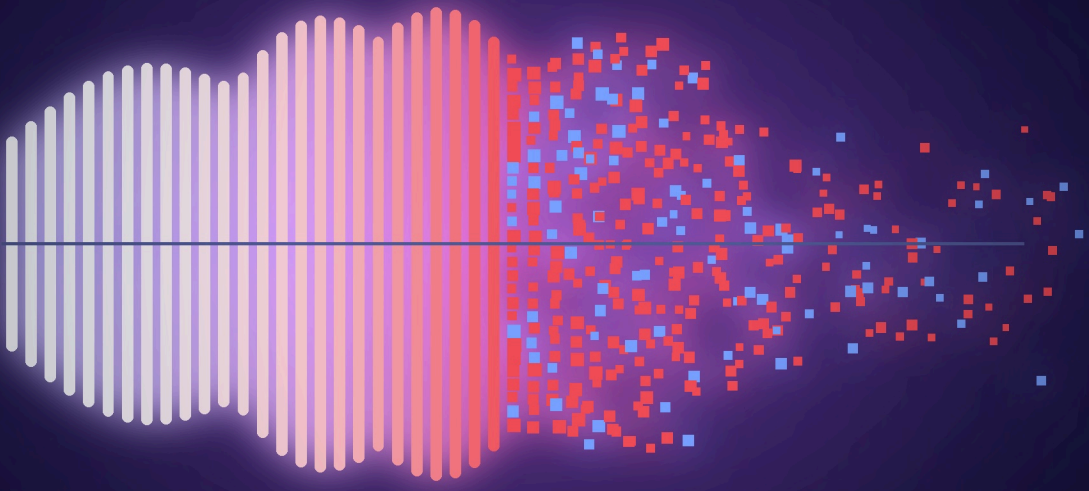
A SMALL BUSINESS SURVIVAL GUIDE

DON'T TRUST THE VOICE



Deepfake Scams, Voice Cloning and Impersonation Fraud

Verify before you pay. Every time.

ZIRLANDIA MILKOVIC

A SMALL BUSINESS SURVIVAL GUIDE

DON'T TRUST THE VOICE

A Small Business Survival Guide to Deepfake Scams, Voice Cloning and Impersonation Fraud

ZIRLANDIA MILKOVIC

Don’t Trust the Voice
A Small Business Survival Guide to Deepfake Scams, Voice Cloning and Impersonation Fraud

© 2026 Zirlandia Milkovic. All rights reserved. No part of this book may be reproduced without written permission, except for brief quotations in reviews.

First edition, 2026. Research cut-off: late October 2026.

This book is practical guidance, not legal, employment, immigration or data-protection advice. Named businesses and people in examples are composites and are labelled as illustrative.

Cover, chapter artwork and diagrams created by the author with code-generated graphics.

Contents

START HERE

Before You Begin 4
Introduction: The Voice You Thought You Knew 5

CHAPTERS

1. The New Face of Impersonation 8
2. Why Smart People Still Get Fooled 14
3. The Five Business Scams to Understand 19
4. The Independent Verification Rule 26
5. The Payment Protection Protocol 31
6. What Employees Must Never Do 37
7. Your Business Deepfake Defence Plan 42
8. If You Think You Have Been Targeted 48
9. Your First Thirty Days 53

CLOSING

Conclusion: A Voice Is Only a Voice 56

APPENDICES

Appendix A: One-Page Payment Verification Checklist 58
Appendix B: Trusted Contact Register (Template) 59
Appendix C: Short Payment Verification Policy (Template) 60
Appendix D: Pause Script Card 62
Appendix E: First-Hour Incident Card 63

BACK MATTER

Sources and Further Reading 64

Before You Begin

Important notice. This book is practical guidance for small businesses. It is not legal, financial, insurance or data-protection advice, and it is not a substitute for advice from a qualified professional who knows your business, your bank and your circumstances. Rules on payment reimbursement, fraud reporting and data-breach notification differ between countries and change often. Where this book mentions a rule or a service, it says what it was checked against; please confirm the current position with your bank, insurer or adviser before you rely on it.

About the examples. Every named business, person and scenario in this book that is not attributed to a source is a composite, written to illustrate a point. Each is marked *Illustrative example*. They are not real events, and any resemblance to a real company or individual is coincidental. Real cases are numbered and listed in *Sources and Further Reading* at the end.

About the statistics. This book contains very few numbers on purpose. Fraud statistics are often produced by vendors with something to sell, and they age quickly. Where a figure appears, the text says where it came from and what it can and cannot show.

Research cut-off. Sources were reviewed in late October 2026.

© 2026 Zirlandia Milkovic. All rights reserved.

Introduction: The Voice You Thought You Knew

It is ten to five on a Friday. Priya, the office manager of a nine-person building-services firm in Leeds, is about to lock up when her mobile rings. It is Mark, the managing director. She knows his voice the way you know the voice of anyone you have worked beside for six years: the slightly rushed delivery, the way he says "right, listen" when something matters.

"Right, listen. I'm in a meeting I can't leave. We've got a supplier who needs paying today or we lose the contract. I'll send you the details. Don't mention it to anyone, I'll explain on Monday. Can you do it before the bank closes?"

Priya does not hesitate for long. Mark is her boss. The voice is Mark's. The request is urgent, a little odd, and entirely plausible. She has made similar payments before.

Except it was not Mark.

This book is about that moment: the few seconds in which a person who is good at their job, loyal to their employer and trying to be helpful decides whether to trust what they are hearing. It is about what happens when a voice, a face, a name on a screen or a message that "sounds right" is allowed to stand in for proof.

Why this book exists

Impersonation fraud is not new. Criminals have been phoning accounts departments pretending to be the boss, the bank or the supplier for decades. What has changed is the cost of doing it convincingly. Software that can copy a voice from a short recording, or place a borrowed face on a live video call, is now widely available.

You do not need to be a victim of a spectacular case to be affected by that shift. You only need to run a business with a bank account, a boss whose voice is on your website, and an employee who wants to help.

Two reported cases show the range. In 2019 the managing director of a UK energy company was reported to have transferred €220,000 after a phone call in which he believed he was speaking to the chief executive of his German parent company. The insurer involved said the victim recognised the accent and the "melody" of his superior's voice. [1] In 2024 the engineering firm Arup confirmed that it had been the victim of a fraud in Hong Kong in which an employee joined a video call where, according to police, everyone apart from the victim was a deepfake of a real person; fifteen transfers totalling HK$200 million were made. [2]

Those are large companies. This book is written for the rest of us: the owner-managed business, the family firm, the five-person agency, the freelancer with a client who pays by bank transfer. You do not have a security department. You do have habits, and habits can be changed.

What this book promises, and what it does not

It promises a **procedure**, not a talent. You will not be taught to hear a fake. Nobody can reliably do that, and this book will explain why. You will be given a small number of rules that work even when the voice is perfect and the video is flawless, because they do not depend on how convincing the fake is.

It does **not** promise that you will never be targeted, or that every attack can be stopped. It promises that you can make yourself a much harder, slower and less rewarding target than the business next door, and that if something goes wrong you will know what to do in the first hour.

The one idea

If you remember nothing else, remember this:

> **The rule.** A familiar voice is not proof of identity. A convincing video is not proof of authenticity. Verify through a trusted, independent channel, every time the stakes are high.

Everything that follows is a way of making that sentence automatic.

How to use this book

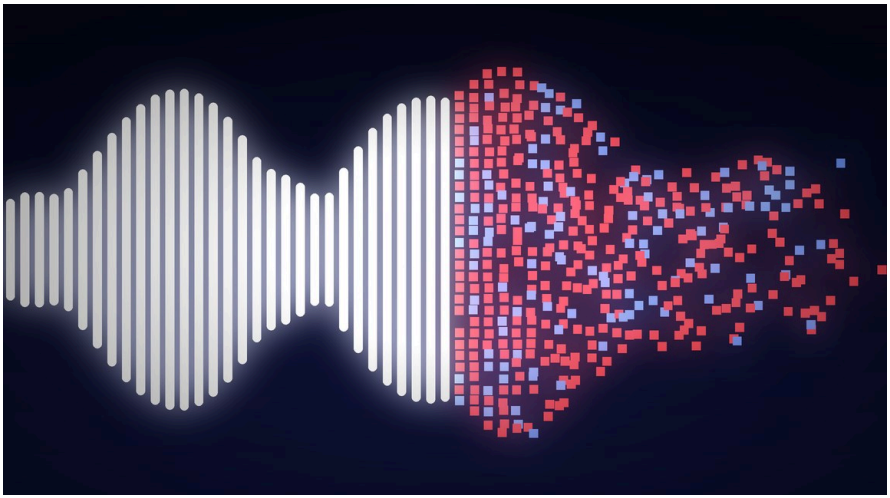
The book is short on purpose. Read Chapters 1 to 3 to understand the threat. Chapters 4 to 6 give you the core rules. Chapters 7 to 9 turn them into a plan for your own business and tell you what to do when something goes wrong. The appendices contain a one-page payment checklist, a pause script, a trusted-contact register and a short payment-verification policy that you can copy, adapt and print.

If you only have an evening, read the Introduction, Chapter 4, Chapter 5 and Appendix A, and hold a ten-minute conversation with your team tomorrow. That alone will put you ahead of most businesses.

A word about tone. People who fall for these scams are not stupid. Priya, in the story above, is conscientious, which is exactly why the call worked. This book does not blame victims. It tries to build a workplace in which doing the right thing is the easy thing.

CHAPTER 1

The New Face of Impersonation



Before we can defend against something, we should be able to describe it in plain English. This chapter explains the vocabulary, how attacks are put together, and, importantly, which parts are established and which are still speculation.

Five terms worth knowing

Social engineering means manipulating a person, rather than a computer, into doing something: paying, sharing, clicking, approving. It is the oldest trick in fraud. A man in a hi-vis jacket carrying a ladder who walks into an office has used social engineering. So has the caller who says, "It's the bank's fraud team."

Impersonation fraud is social engineering in which the attacker pretends to be someone the victim trusts or must obey: a director, a colleague, a supplier, a customer, a bank, a regulator.

Voice cloning is the use of software to produce speech that sounds like a specific real person. Some tools need only a short sample of that person's voice, and many people's voices are public: on a website video, a podcast, a conference talk, a voicemail greeting, or social media.

Deepfake is a general word for synthetic or manipulated audio, image or video that appears to show a real person saying or doing something they did not. The term covers a face swapped onto another body, a cloned voice laid over a recording, or a fully generated clip.

Synthetic media is the wider category: any audio, image or video produced or altered by software.

What a cloned voice is, and is not

A cloned voice is not a recording of your boss that the criminal has edited together. Modern tools can generate *new* sentences that your boss never said, in something close to their voice, and some can do so in near real time during a phone call. The quality varies. Some clones are obviously robotic. Some are convincing enough to fool a colleague on a poor mobile line, which is exactly where a fraudster wants the call to take place.

Two things make this easier for criminals than it sounds.

First, **phone lines hide flaws.** Compression, background noise and a bad signal explain away almost any oddity. "You sound a bit strange" is met with "I'm on the train."

Second, **the voice does not have to be perfect, only good enough for a stressed person in a hurry.** Fraud is a numbers game. An attacker who contacts fifty businesses needs one to fall for a mediocre fake.

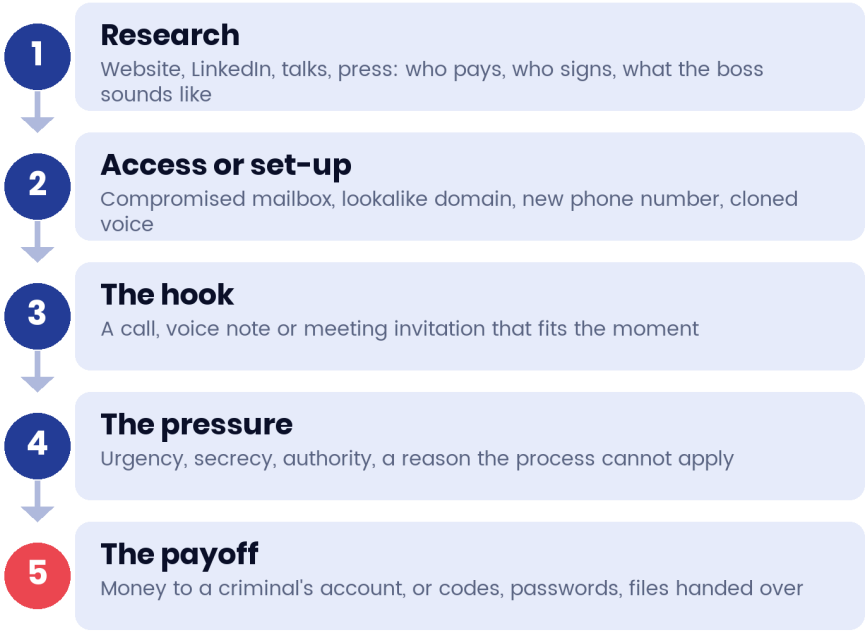
What a deepfake video call is, and is not

Live video manipulation is harder than cloning a voice. In the most elaborate reported cases, such as the Arup fraud described in the Introduction, the victim was reported to have been outnumbered on a call by apparent colleagues, which creates powerful social proof: if everyone else on the screen seems to agree, doubting feels rude. [2]

It is worth being measured about this. Most business fraud today does not involve live deepfake video. It involves email, text messages, ordinary phone calls and fake invoices. But it is precisely because video is the form people say they would *trust* that it is worth planning for. The honest position is: **live video impersonation is possible, still comparatively rare and likely to become cheaper.** A procedure that already covers it costs you little.

How the pieces fit together

Attackers rarely use one technique alone. A typical attack combines several steps, each simple on its own.



How a typical impersonation attack is assembled

1. **Research.** Company website, LinkedIn, press releases, social media, conference videos. Who is the director? Who handles payments? Who are the suppliers? What is the director's voice like?
2. **Access or preparation.** In some attacks, a real email account has been compromised, so the fraudulent message arrives from a genuine address inside an ongoing thread. In others, the attacker registers a near-identical domain name, or simply uses a free email address with the director's name.
3. **The hook.** A message, a call or a meeting invitation creates the setting for the request.
4. **The pressure.** Urgency, secrecy, authority, a plausible reason why the usual process cannot be followed.

5. **The payment or the data.** Money moves to an account the attacker controls, or credentials, codes or documents are handed over.

Notice that the voice or video is only one link in the chain. Remove any link and the attack gets harder. That is why a procedure beats a hunch.

Established, emerging and speculative

It helps to separate what is happening now from what might happen.

Category	Examples	How to treat it
Established	Fake invoices, bank-detail change requests, "urgent request from the CEO" emails, compromised email accounts, phone calls impersonating banks, fake IT support asking for codes	Plan for these now. They account for most real losses.
Emerging	Cloned voices on phone calls and voice notes, voice messages on messaging apps, deepfake video in meetings, AI-written messages with no spelling mistakes	Assume these are possible. Make sure your procedures do not rely on the voice or face being genuine.
Speculative	Fully automated real-time conversations at scale, perfect video clones of any employee from a single photo	Do not build your plan around these. If your rules ignore the voice and face, you are already covered.

This table is the quickest way to keep fear in proportion. You do not need to be an expert in artificial intelligence. You need to be good at the basics, and the basics happen to defeat the clever stuff as well.

What this means for a small business

Three practical consequences follow.

Your public voice and face are raw material. You cannot remove them. You should simply stop treating them as a password. Many employees treat "I recognised their voice" as the strongest form of verification; it is now one of the weakest.

Writing quality is no longer a signal. Older advice told people to look for spelling mistakes and awkward grammar. AI tools produce fluent English. A message that reads well is not therefore genuine.

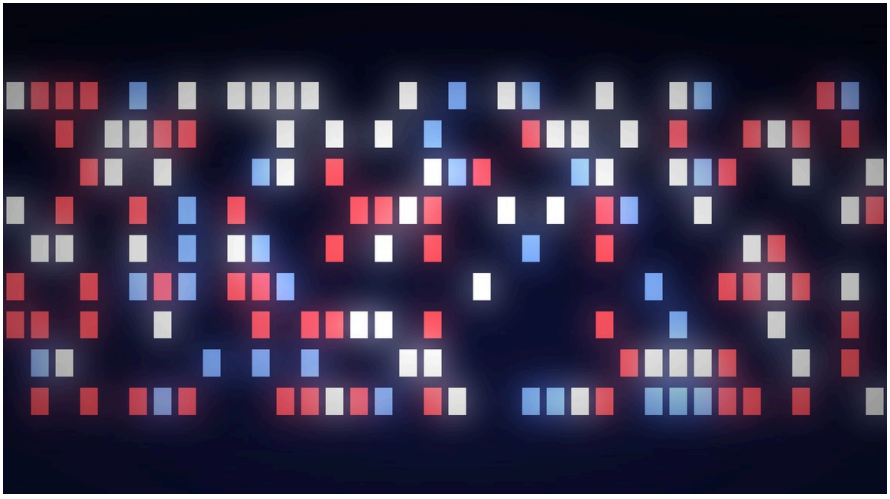
The weak point is the decision, not the technology. The question is never "Is this deepfake good?" The question is "Would we release this payment on this basis?" If the answer is no regardless of how real it sounds, the technology has nothing to attack.

Key takeaways

- Voice cloning and deepfake video are real but only one part of a longer attack chain.
- Established tricks, such as bank-detail changes and fake urgent requests, still cause most losses.
- Plan around the decision (verify before you pay), not around spotting fakes.

CHAPTER 2

Why Smart People Still Get Fooled



When a business loses money to a scam, the first question is often, "How could they fall for that?" It is the wrong question. A better one is, "What was done to make the right decision harder?"

Scams do not work because people are careless. They work because they are designed to take advantage of ordinary, usually admirable, instincts: helpfulness, loyalty, respect for authority, and a wish to get things done. This chapter explains the main levers fraudsters pull.

Six pressures



The six pressures that bypass verification

1. Urgency and time pressure

"I need this in the next hour." Urgency shrinks the space in which we think. People under time pressure fall back on habit and skip optional steps. Fraudsters know this and rarely run long, patient stories when a ticking clock will do. A real emergency is rare; an *invented* emergency is the criminal's favourite tool.

Look for: deadlines that are tight and arbitrary ("before the bank closes", "before the meeting starts"), and threats of a lost contract, penalty or embarrassment.

2. Authority and hierarchy

We are trained to follow instructions from people more senior than us. Few employees feel entitled to question the managing director. When the "managing director" calls, the question in the employee's mind shifts from "Is this right?" to "How do I do what I've been asked?"

Look for: requests that come from the top of the organisation but bypass the normal routes, or that ask you to ignore a procedure the director themselves introduced.

3. Fear of disappointing a manager

Nobody wants to be the person who slows things down. In smaller firms the relationship with the owner is personal: your livelihood depends on it. The thought "What if it's real and I've delayed it?" feels more dangerous than "What if it's fake and I've paid it?" Fraudsters rely on that asymmetry.

4. Familiarity and trust

We trust what we recognise: a known voice, a known email name, a known supplier's logo, a known sign-off. Familiarity is a shortcut our brains use all the time, and generally a reliable one. Synthetic media attacks that shortcut directly. The brain registers "that's Mark" within a second and the rest of the evaluation is quietly switched off.

5. Secrecy and isolation

"Don't tell anyone." "Keep this between us." "I'll explain on Monday." Secrecy removes the colleague who would have said, "That doesn't sound right." It also makes the victim feel special and trusted, which makes refusal harder. **Any instruction that discourages you from checking with a colleague is a warning sign in its own right.**

6. Routine disruption and distraction

Attacks cluster around moments when normal processes are weak: Friday afternoons, bank holidays, holiday cover, staff leave, a busy month-end, a new starter who does not yet know who is who. A request that would fail on a quiet Tuesday can succeed at ten to five on a Friday.

Why this affects capable people

It would be comforting to believe that clever people are immune. The opposite is often true. People who are conscientious, fast and eager to help are the people who get things done and the people a fraudster most wants to reach. Experience can even work against you: a confident finance assistant who has handled hundreds of legitimate urgent payments may have a well-practised habit of acting quickly.

> **Illustrative example: Dev and the missing second pair of eyes.** Dev runs a four-person marketing agency in Manchester. His finance assistant, Chloe, has a clean record. One Thursday evening she receives a WhatsApp voice note, apparently from Dev, saying he is travelling and needs £6,800 sent to a freelancer who has "just finished a rush job". The voice sounds right and the note is brisk and friendly. She pays it. The voice note was generated from a conference talk Dev gave last year. Chloe did nothing unusual by the standards of the business. The agency simply had no rule that said a payment to a new payee needed a second person, and no rule that said instructions on a messaging app do not count.

The lesson is that the **business**, not Chloe, had the gap.

What the lures have in common

If you read many of these cases, a small pattern appears. The request almost always has most of the following features.

- It is **unexpected** and arrives outside the usual process.
- It involves **money, credentials or confidential data**.
- It carries **time pressure**.
- It cites **authority** or a plausible high-stakes reason.
- It asks for **secrecy**, or makes checking awkward.

- It offers contact details or links **only within the message itself**, so the only way to "verify" is to ask the sender.

You do not need all six. Two or three together should trigger the procedure in Chapter 4.

Why "be vigilant" is not enough

Many organisations respond to fraud risk with a poster saying "Think before you click." Vigilance is not wrong, but it is a poor control on its own, because it relies on a person remaining sharp, calm and confident at the moment when someone has gone to some effort to make them feel the opposite.

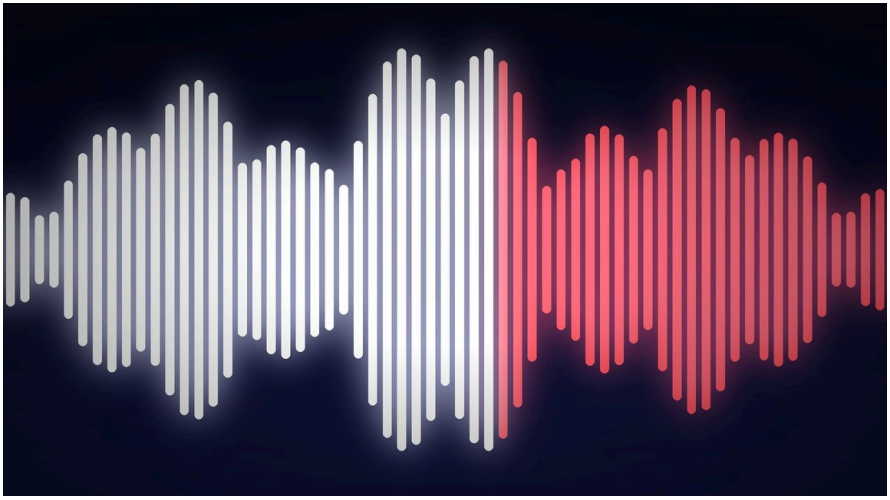
A better design principle is **make the safe action the default action.** If your payment process requires a second person for new payees, nobody has to be brave. If your policy says that no one may be punished for pausing a request, nobody has to risk their job to ask a question. Good rules take the pressure off individuals.

Key takeaways

- Fraudsters exploit helpfulness, loyalty and respect for authority, not stupidity.
- Six pressures recur: urgency, authority, fear of disappointing, familiarity, secrecy and disruption.
- Build rules that remove the need for individual bravery. Do not blame the person who was targeted.

CHAPTER 3

The Five Business Scams to Understand



This chapter walks through five scenarios. All are **fictional and illustrative**: composites based on the patterns described in public reporting, with invented people and businesses. For each one you will see the opening message, the warning signs, what the employee should do, the right way to verify, and the lesson for the business.

	SCAM	CHANNEL	THE ASK	THE SAFE MOVE
1	**Fake CEO**	Voice note / call	Urgent transfer	Call back on saved number
2	**Supplier change**	Email + phone	New bank details	Verify via your own records
3	**Deepfake meeting**	Video call	Deposit “today”	Authorise afterwards, two people
4	**Fake customer**	Phone + email	Confidential files	Call back, use address on file
5	**Fake IT**	Phone	Code + remote access	Hang up, call real IT

The five scams at a glance

Scam 1: The fake CEO and the urgent transfer

> **Illustrative example.** Northgate Joinery is a 14-person firm in Sheffield. At 16:40 on a Thursday, Aisha in accounts receives a voice message on WhatsApp from a number she does not have saved. It sounds like the owner, Tom Hargreave: "Aisha, it's Tom, new number, I've lost my phone. I need you to make a payment of £18,500 today to a supplier for the Bradford job. It's confidential until the deal is signed. Message me back here and I'll send the account details."

Warning signs

- A new number claiming to be a known person.
- A payment outside the normal supplier process.

- Urgency ("today") and confidentiality.
- Account details to be supplied through the same unverified channel.

What the employee should do. Do not reply on the new number and do not make any payment. Say nothing that confirms internal details. Contact Tom through the number saved in the company directory, or in person, and tell the finance lead.

Correct verification. A call back to Tom's *previously saved* mobile, or a walk to his office. If he cannot be reached, the payment waits. The second approver confirms recipient, amount and purpose before any money moves.

Lesson for the business. "New number" messages are a classic opening. Agree in advance that **no payment is ever authorised through a messaging app**, however familiar the sender sounds.

Scam 2: The supplier changes their bank details

> **Illustrative example.** Bluebell Catering buys from a regular dairy supplier. An email arrives, apparently from the supplier's accounts contact, in the same thread as previous invoices: "We have changed bank. Please use the new details below for the attached invoice and all future payments." A follow-up phone call, from someone who sounds like the usual contact, confirms it. The new account is at a different bank.

Warning signs

- Bank details that change mid-relationship.
- A change communicated by the same channel that carries the invoice.
- A "confirming" call from a number the requester supplied.
- Pressure to apply the change immediately.

What the employee should do. Pause the payment. Do not amend the supplier record yet. Contact the supplier using the number in your **own** records, the contract or a previous invoice you trust, never the one in the new email.

Correct verification. Ask the supplier, through your own known contact, whether they requested a change. Record who you spoke to, when, and which number you used. Require a second person to approve any supplier bank-detail change. If you use the UK Confirmation of Payee check, treat a "no match" as a stop, not an inconvenience.

Lesson for the business. A bank-detail change is a **change request, not a payment**, and it deserves its own approval step. This is one of the most common routes to loss because it can be done by email alone, and a convincing phone call is easy to add.

Scam 3: The deepfake video meeting

> **Illustrative example.** Harbourside Logistics (22 staff, Bristol) has recently been approached by a possible acquirer. The finance manager, Ewan, receives a calendar invitation for a "confidential call about the acquisition", apparently from the finance director. On the call he sees the finance director and two colleagues. The director says the deal needs a deposit of £95,000 paid today to an escrow account and asks Ewan to keep the call confidential.

Warning signs

- An unusual, confidential meeting that bypasses normal channels.
- A request for a significant payment during or straight after the meeting.
- Pressure created by several "senior" people agreeing.
- A link or invitation Ewan did not expect.
- Camera or audio quirks explained away ("bad connection").

What the employee should do. Do not make the payment during the call. Say, politely, that company policy requires a separate confirmation for payments over a set threshold. End the call and verify using a trusted channel.

Correct verification. Contact the finance director using the number in your staff directory. Involve the second approver. Treat the meeting itself as *a claim to be checked*, not as proof.

Lesson for the business. A video meeting is not an authorisation. Make it a written rule that **no payment is authorised in a meeting, call or chat**; authorisation happens afterwards, through your payment system, with two people.

Scam 4: The impersonated customer requesting information

> **Illustrative example.** Fernhill Accountancy receives a call from someone who says he is a long-standing client, Mr Okafor. He is calling from a different phone because his own is broken, he says, and he needs his last three years of tax documents and bank details emailed to a new address "right now, because HMRC has asked for them". He knows his accountant's first name and the last invoice amount.

Warning signs

- A new phone number and a new email address.
- Pressure referencing a deadline or an authority.
- Details that sound private but could have been obtained elsewhere.
- Confidential files requested to an address not already on record.

What the employee should do. Send nothing. Explain that you will call back on the number you hold on file. Check whether there is any existing contact record before sharing anything.

Correct verification. Call back on the number in the client file or ask a question only the real client would know, from your records and not from the call. Send documents only to the address already on file, or via the secure portal.

Lesson for the business. Knowing internal details does not prove identity. Attackers collect small facts from earlier breaches, social media and previous phone calls. Customer impersonation also carries a data-protection dimension: sending personal data to the wrong person can be a personal-data breach.

Scam 5: The fake IT or security employee

> **Illustrative example.** Willow & Finch, a design studio of seven, gets a call from "Sam from IT support". Sam says the company's Microsoft 365 account has shown suspicious sign-ins and that he needs to verify Lena's identity. He asks her to read out the six-digit code that has just been sent to her phone, and then to install a "security tool" so that he can check her laptop.

Warning signs

- An unexpected call about a security problem.
- A request for a one-time code or password.
- A request to install remote-access software.
- Pressure to act before the "breach" gets worse.

What the employee should do. Hang up. Do not read out the code. Do not install anything. Report the call to the person responsible for IT, or the owner, straight away.

Correct verification. Contact the genuine IT provider using the number in the contract or your trusted register. If there is a real problem, the IT provider will not need a code read out to them. **No legitimate provider asks you to read out a one-time code.**

Lesson for the business. One-time codes exist to prove the *account owner* is present. Handing one over is the equivalent of giving away the key. Make this a one-line rule everyone remembers: **"Codes are never read out."**

What the five have in common

	Channel	The ask	The safe move
1. Fake CEO	Messaging app voice note	Urgent payment	Call back on saved number; no payments via chat
2. Supplier change	Email + phone	New bank details	Verify with number from your own records
3. Deepfake meeting	Video call	Deposit payment	Authorise afterwards, two people
4. Fake customer	Phone + email	Confidential files	Call back; use address on file
5. Fake IT	Phone	Code + remote access	Hang up; contact real IT

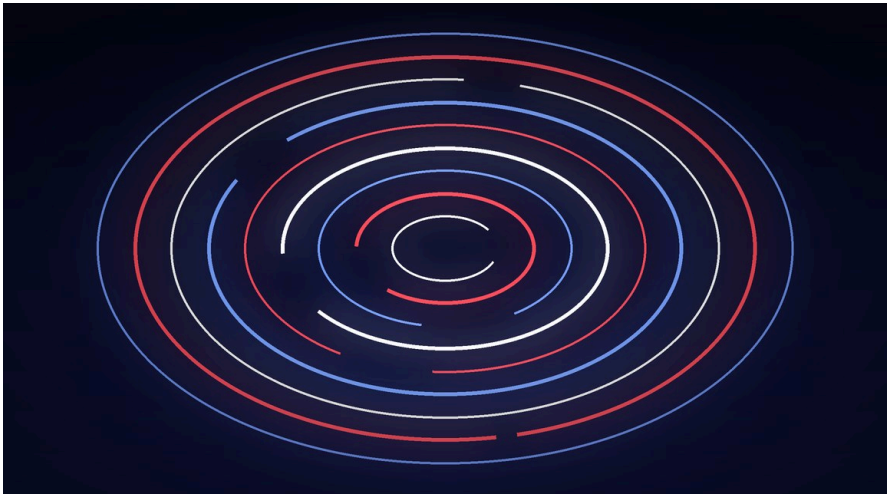
Every one of these is defeated by the same move: **stop, then verify through a channel the attacker does not control.**

Key takeaways

- Five scenarios cover most of what small businesses face: fake boss, changed bank details, deepfake meeting, fake customer, fake IT.
- The attacker always controls the channel they started on. Switch to one they do not control.
- Details, accents, faces and confident manners prove nothing.

CHAPTER 4

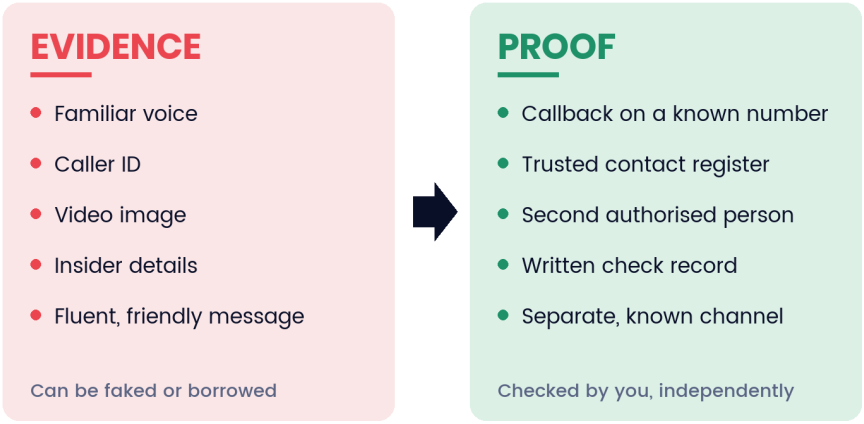
The Independent Verification Rule



If this book has a centre, this is it. The rule is simple to state and surprisingly hard to practise under pressure.

> **The rule.** Whenever a request involves money, credentials, or confidential data, verify the requester through a trusted, independent channel *that you choose*, not one that the requester supplies.

Each word matters. *Trusted* means you had the contact details before this request arrived. *Independent* means the attacker is not in control of it. *You choose* means you look up the number; you do not take it from the message, the caller, the signature, or the meeting invitation.



Evidence versus proof

What is not proof of identity

Print this list and pin it up.

- **Caller ID.** It can be spoofed. A call can display the real bank's number, your director's number or a number from your contacts.
- **A familiar voice.** Cloning, impressions and recordings can all reproduce it.
- **A video image.** Live face manipulation is possible, and a video recording can be pre-recorded or edited.
- **Knowing internal details.** Names, invoice values and project codes leak through earlier breaches, compromised mailboxes and ordinary oversharing.
- **A message from a known email address.** The account may have been compromised, or the address may be a lookalike.
- **A confident, friendly manner.** This is the oldest trick of all.
- **An email thread that "looks right".** Attackers can insert themselves into real threads after compromising a mailbox.

What counts as independent verification



The callback flow

1. **Call back on a number you already hold.** Use the contract, your saved contacts, a previous invoice you trust, or the company's own directory. Do not use "reply", the number on the incoming call, or any contact detail inside the message.
2. **Use a known directory.** Keep a short, controlled list of trusted contacts for directors, key suppliers, your bank and your IT provider (Appendix B gives a template).
3. **Switch channels.** If the request came by email, verify by phone. If it came by phone, verify through a face-to-face conversation or a pre-agreed internal channel.

4. **Confirm bank-detail changes separately.** Always treat a request to change bank details as its own approval, with its own record.
5. **Use a second authorised person for high-risk actions.** Two people reduce the chance that one tired, pressured person is the only defence.
6. **Use a pre-agreed verification phrase for senior-level requests, if it suits your culture.** Some families and businesses use a shared code word or question that is never written in email. It is not a perfect control, since a phrase can leak, so use it as a supplement and not a substitute for callback.
7. **Avoid contact details that appear only in the suspicious request.** If the only way to check is to ask the sender, you have not checked.
8. **Document the result.** Write down who verified, how, when, and what the answer was (Appendix A has a space for this).

A worked example

Let's return to Priya from the Introduction. The call comes in at ten to five.

- **Pause.** She says, "Mark, I just need to take a note of the details. Let me call you straight back on your usual number."
- **Switch channel.** She hangs up and calls Mark's saved mobile. It rings out. She walks to the office diary, sees that he is at a client's site, and phones the client's reception.
- **Second person.** She tells the finance lead, Hannah, who confirms there is no such supplier on file.
- **Record.** Priya writes a short note: time, caller, what was asked, what she did.

The whole thing takes four minutes. A genuine request survives a four-minute check. A fake does not.

Handling the awkward moment

The hard part is social, not technical. Employees worry about offending the boss. The remedy is to settle it **in advance**, in writing, from the top:

> "If anyone, including me, asks you to make a payment, change bank details or share a password, I expect you to verify first. If I am angry that you checked, I am wrong."

When the director has said that out loud, the employee has permission. Chapter 6 gives a short script.

What if the genuine person really cannot be reached?

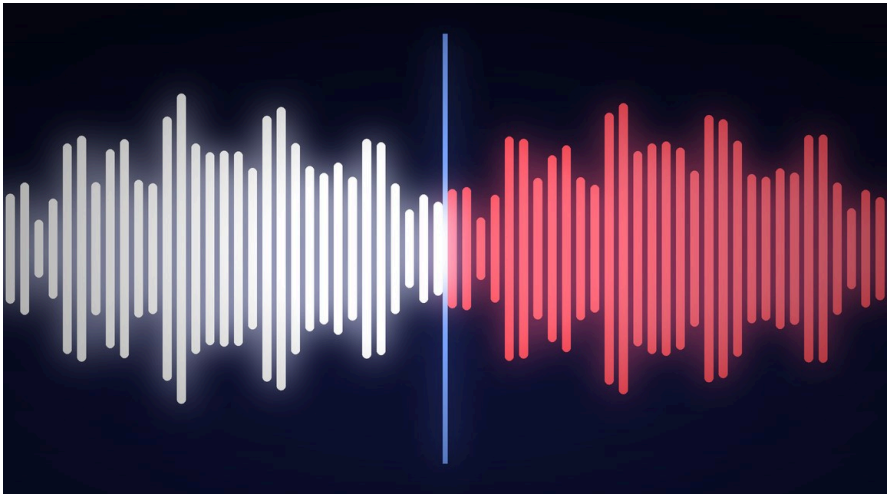
Sometimes the owner really is on a flight. The answer is still the same: **the payment waits** or follows a pre-agreed emergency route involving a second authorised person, never a rush on a single person's conscience. Few payments are so urgent that a four-hour delay causes harm that outweighs the risk of a six-figure loss. If your business regularly has genuine emergencies, build an emergency approval route into your policy (Chapter 7).

Key takeaways

- Verify through a channel you choose, using contact details you already hold.
- Caller ID, voice, video, insider facts and good grammar are not proof.
- Make verification normal, written and supported from the top, so nobody feels rude.

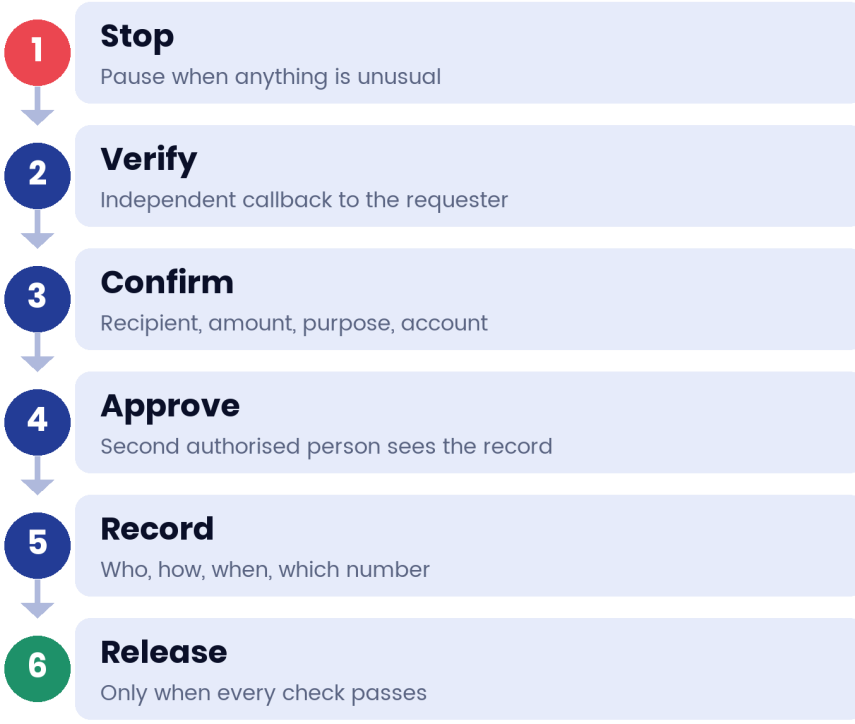
CHAPTER 5

The Payment Protection Protocol



Chapter 4 told you how to verify a person. This chapter turns that into a repeatable procedure for **payments and financial changes**: the moments where a mistake costs money.

The protocol has six steps. It is deliberately short, because a procedure nobody remembers is a procedure nobody follows.



The six-step Payment Protection Protocol

The six steps

Step 1: Stop when something is unusual

Unusual does not mean suspicious. It means *different from the normal pattern*: a new payee, a changed bank account, an unusual amount, an unusual request route, a payment without a purchase order, a strange hour. At this step you do nothing except pause. Nobody is accused of anything.

Step 2: Verify the requester independently

Apply the rule from Chapter 4. Call back on a known number or speak to the person face to face. If the request claims to come from a supplier, use the contact details in your own records.

Step 3: Confirm recipient, amount, purpose and account details

Four questions, answered from your own documents:

- **Recipient.** Is this the payee on our records, spelled exactly as we expect?
- **Amount.** Does it match the invoice, purchase order or contract?
- **Purpose.** Do we know what we are paying for, and did someone in the business ask for it?
- **Account.** Do the sort code and account number (or IBAN) match the supplier record that was *independently verified*? Run the bank's name-matching check where it is offered, and treat a mismatch as a stop.

Step 4: Obtain the required second approval

The second approver must be a different person, and must see the verification record, not just the payment screen. A "rubber stamp" second approval defeats the purpose. Agree that the approver is entitled to ask, "How did you verify this?"

Step 5: Record the verification

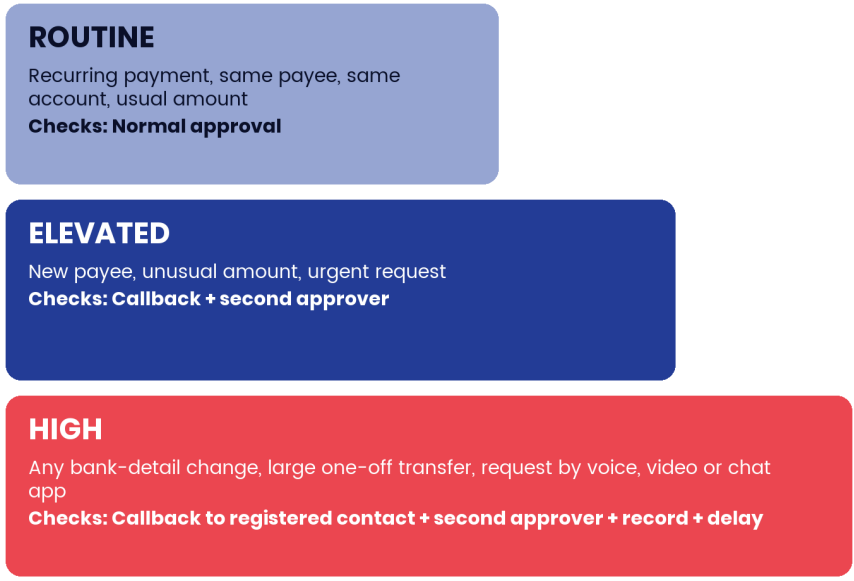
A short note is enough: who requested, who verified, by what method, which number was called, what the answer was, and who approved. The record helps if something later goes wrong, it makes the process visible, and it makes shortcuts embarrassing.

Step 6: Release the payment only when all checks pass

If any step fails or cannot be completed, the payment waits. "I'll fix it on Monday" is an acceptable outcome. A payment that cannot pass the checks is exactly the payment you do not want to make.

Make it proportionate

A control that is too heavy will be bypassed. One that is too light will not protect you. Match the checks to the risk. Here is one simple way to tier them.



Risk tiers for payments and changes

Risk level	Example	Minimum checks
Routine	Recurring payment to a long-standing supplier at the usual account and amount	Normal approval; no extra step
Elevated	First payment to a new payee; amount well above normal for this supplier; urgent request	Independent callback + second approver
High	Any change of bank details; large one-off transfer; anything requested by voice, video or messaging app; payments to a new country	Independent callback to a pre-registered contact + second approver + written record + delay until all checks complete

The thresholds are yours to set. A five-person firm might treat anything over £1,000 as elevated and anything over £10,000 as high. A larger business will set figures that suit its scale. The important thing is that **the thresholds are written down before the pressure arrives.**

> **Note on fit.** Verification controls should reflect your size, your risk and your legal obligations. If you are regulated, or handle client money, your regulator or insurer may require specific controls. Treat this book's framework as a starting point and check what your bank, insurer or adviser requires.

What banks can and cannot do

In the UK, many banks offer a name-matching check ("Confirmation of Payee") and will question unusual payments. These are helpful but not guarantees. A criminal can open a real account in a real name, and a payment you *authorise* yourself, even when you were deceived, is treated differently from an unauthorised one.

Reimbursement rules for payments made by Faster Payments or CHAPS between UK accounts, introduced by the payments regulator from October 2024, can in some circumstances cover small businesses, charities and individuals who were deceived into authorising a payment. According to public summaries reviewed for this edition, the scheme is limited to micro-enterprises (broadly, fewer than ten employees and turnover or balance sheet up to £2 million), has a maximum of £85,000 per claim, and requires claims within 13 months. [3] These are **not** a reason to relax: eligibility depends on facts, your bank's decision and your own conduct, and many businesses fall outside it. Ask your bank directly what applies to you.

The one-page checklist

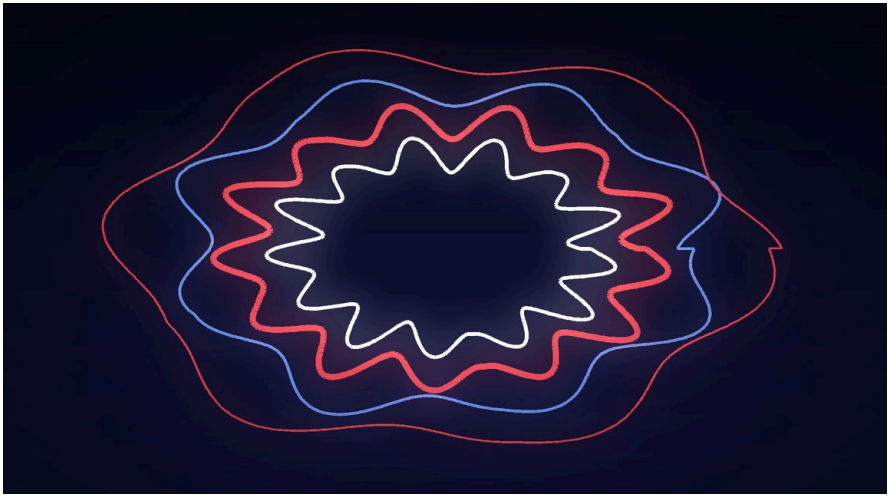
Appendix A contains a one-page printable version of this protocol. Print it. Put it where payments are made. Make filling it in part of the job.

Key takeaways

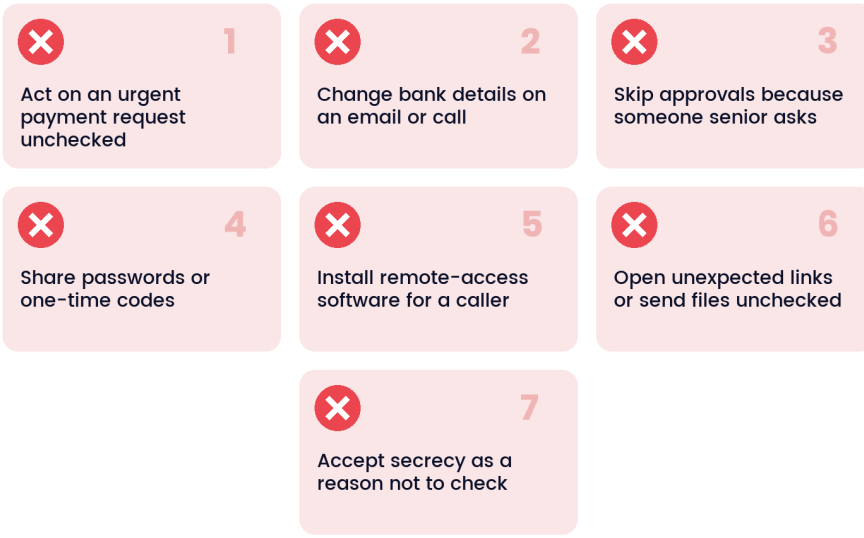
- Six steps: stop, verify, confirm the details, second approval, record, release.
- Scale the checks to the risk and write the thresholds down.
- A payment that cannot pass its checks is a payment that waits.

CHAPTER 6

What Employees Must Never Do



Rules work best when they are short, memorable and phrased as things nobody has to agonise over. This chapter gives you a set of "never" rules, together with a short script for pausing a request politely.



The seven "never" rules

The seven rules

1. Never act on an urgent payment request without verifying it

Urgency is the one feature that appears in nearly every fraud. If the request is urgent *and* involves money, the verification steps are not optional. If the person is genuine, they will understand.

2. Never change supplier bank details on the strength of an email or a phone call

Treat any change as a request that must be verified through a known number, recorded and approved by a second person. This applies even if the email arrives in an old, familiar thread.

3. Never bypass normal approvals because someone senior asks you to

A genuine senior person will not mind following the process they created. If they are annoyed that you followed it, that is a conversation for them to have with themselves, and the policy supports you.

4. Never share passwords, one-time codes or authentication prompts

This includes sharing them with "IT", "the bank", "the police", the boss or a colleague who is "locked out". Genuine organisations do not ask you to read codes aloud. If you approve a login prompt you did not trigger, you may be letting the attacker in.

5. Never install remote-access software at someone else's request

Tools that let another person control your computer are legitimate in the right hands and devastating in the wrong ones. Only the person responsible for IT should decide whether such software is installed, and only after verifying the request.

6. Never open unexpected links or attachments, or send confidential files on request, without checking

A link in a message is the attacker's channel. A file sent to the wrong address is a potential personal-data breach as well as a business risk. If a colleague or customer asks for sensitive documents, confirm through another route and use the secure channel you already have.

7. Never accept secrecy as a reason to skip checking

"Don't tell anyone", "keep this confidential", "I'll explain later". Legitimate confidentiality exists, but it never prevents you from asking a second authorised person to confirm a payment. Confidentiality is a reason to involve fewer people, not to involve nobody.

The pause script

The social cost of checking is the main obstacle, so give your staff words. Here are a few that are polite, short and do not accuse anyone.

On the phone

> "Thanks, I've got that. Our process means I need to confirm any payment like this before it goes. I'll call you straight back on your usual number."

On video or in a meeting

> "I can't release this on the call, as it needs a second approval. I'll follow up with you afterwards through the normal route."

By message or email

> "Thanks for this. Before I act, I'm going to confirm it with you through our usual channel, as we do for all payment changes. I'll come back to you shortly."

If the person pushes back

> "I understand it's urgent. This is the process for everyone, and it protects you as well as us. If it's genuine, it will only take a few minutes."

If you are not sure and are alone

> "I'm going to check with [finance lead / owner] first. I'll be back to you in ten minutes."

A pushy reaction to a polite pause is itself information. A genuine colleague accepts the check. A fraudster escalates, flatters, threatens or disappears.

Rules for the owner too

The rules fail if the owner is the exception. Agree that the director's own requests go through the same checks. Many successful frauds exploit the one person who "never has to follow the process".

> **Illustrative example: The owner who went first.** A garden-design business owner announced at a team meeting that any request from him to pay money would be verified by call-back, and that he would be pleased, not cross, if staff did so. The following month he deliberately sent a test payment request from his personal phone. His office manager called him back on his saved number and thanked him for the test. The team has not been caught out since. The lesson is that **the culture is set by what the senior person does when tested.**

No blame, and report quickly

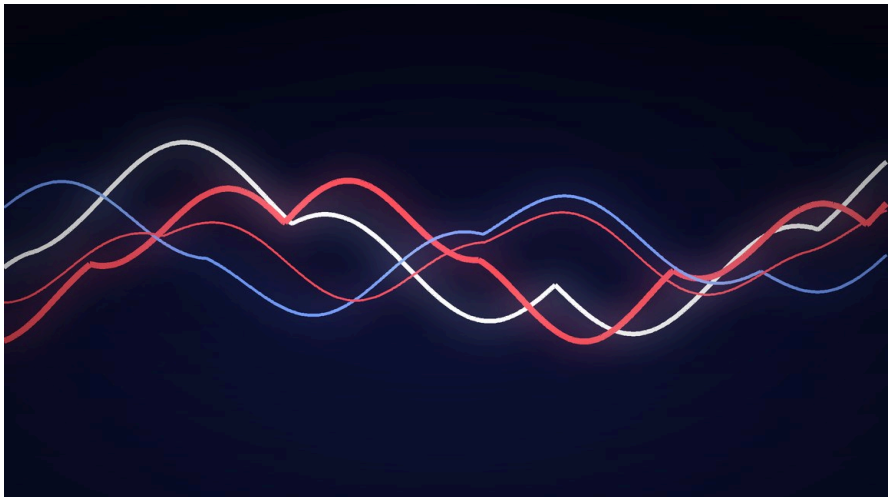
Add one more rule to the list: **tell someone straight away if you think you have been fooled.** The first hour matters (Chapter 8). A business that punishes honest mistakes will hear about them late, if at all. A business that thanks people for reporting will hear about them while there is still time to recall a payment.

Key takeaways

- Seven simple "never" rules cover most of the risk.
- Give employees a script so that pausing is polite, not confrontational.
- The owner is subject to the same rules. Report quickly and without blame.

CHAPTER 7

Your Business Deepfake Defence Plan



You now have the rules. This chapter shows how to turn them into a **proportionate, affordable** defence plan for a small business. None of it requires specialist software.



Three layers of defence

Layer 1: People

Staff awareness training

Run a short session, thirty minutes at most, at least once a year and for every new starter. Cover:

- The five scams in Chapter 3.
- The Independent Verification Rule.
- The seven "never" rules.
- Who to tell, and how, if something seems wrong.

The most effective training is concrete. Play a short, **consented** example of a cloned voice (your own, with your agreement) to show colleagues how convincing a short sample can be. Use a quiz or a "what would you do?" scenario instead of a lecture. Repeat the key points every quarter in a few lines.

A no-blame reporting culture

Name one person who receives reports. Make it clear that reporting a mistake or a near miss will be thanked.

Layer 2: Process

A written payment-verification policy

One page is enough. Appendix C is a template. It should say what counts as a payment request, who may authorise what, the thresholds, the callback rule, who may change supplier records, and what to do in an emergency.

Trusted contact records

Maintain a short register of key contacts with their **independently confirmed** phone numbers: directors, your bank relationship manager, your accountant, key suppliers, your IT provider. Restrict editing and review it twice a year. Appendix B has a template. Add contacts when you are on a genuine, trusted call, not in response to a request.

Segregation of duties

Where possible, the person who **requests** a payment, the person who **sets up or changes** a payee and the person who **approves** it should be different. In a two-person business, this might mean the owner approves everything that the bookkeeper prepares, and the bookkeeper may not release anything alone.

Approval thresholds

Set levels that reflect your cash flow and appetite for risk. Example for a ten-person firm:

Amount	Approval needed
Up to £1,000 to an existing payee	One authorised person
£1,000 to £10,000, or any new payee	Callback + second approver
Over £10,000, or any bank-detail change	Callback to registered contact + second approver + record + delay

Choose your own figures, and write down the reason.

An emergency route

Real emergencies happen. Define who may approve in an emergency, how they are verified, and what the maximum amount is. Having a route removes the excuse for bypassing it.

Layer 3: Technology

You do not need an expensive security stack. Prioritise the basics.

Strong authentication. Turn on multi-factor authentication (MFA) for email, banking, accounting software, cloud storage and any admin account. Prefer authenticator apps or hardware security keys over codes sent by text message where the service allows, because text messages can be diverted or phished. Where "passkeys" are offered, they resist phishing better than passwords and codes. Each person should have their own login: no shared accounts.

Secure account recovery. Attackers often take over an account by abusing "forgot my password". Check the recovery email address and phone number on your most important accounts (the email domain, bank, domain registrar, payroll). Use a business-controlled recovery address. Protect your mobile phone account with a PIN so that your number cannot be moved to another SIM without your involvement.

Email hygiene. Enable the sender-authentication settings (SPF, DKIM and DMARC) on your own domain so that others can tell your genuine mail from forgeries. Your email or website provider can usually do this for you. Turn on warnings for external senders, and consider registering the obvious lookalike versions of your domain name.

Payment controls. Use your bank's dual-authorisation setting for business accounts and set payment limits. Ask your bank about alerts and name-matching features.

Device and software updates. Keep systems updated and use reputable security software. Many national schemes, such as the UK's Cyber Essentials, offer a structured baseline for small organisations at a modest cost.

Be thoughtful about your public voice and face. You do not have to disappear from the internet. But think about who needs to hear a director's voice for ten minutes at a time, and avoid publishing unnecessarily long, clean recordings of key people. More important than hiding is making the voice irrelevant as proof.

Insurance

Some cyber and crime insurance policies cover social-engineering losses, but many have conditions, sub-limits or exclusions, for example requiring that a callback was made. Ask your broker in plain terms: "*If an employee is deceived by a cloned voice into paying a fraudulent invoice, are we covered, and what controls must we have followed?*" Keep the answer in writing.

A note on data protection

Impersonation attacks often involve personal data: customer files, staff details, payroll. If you handle personal data of people in the UK or EU, the data-protection rules also expect you to protect it with appropriate security measures and, in many cases, to notify the regulator of certain breaches quickly. The verification rules in this book are good data-protection practice as well as good fraud prevention. Chapter 8 returns to this.

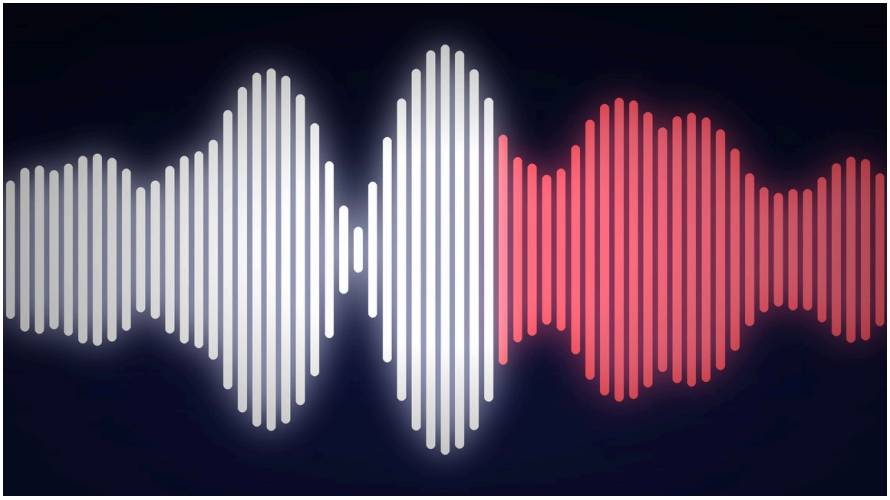
Key takeaways

- Defend in three layers: people, process, technology.
- Write a one-page payment policy, a trusted-contact register and approval thresholds.

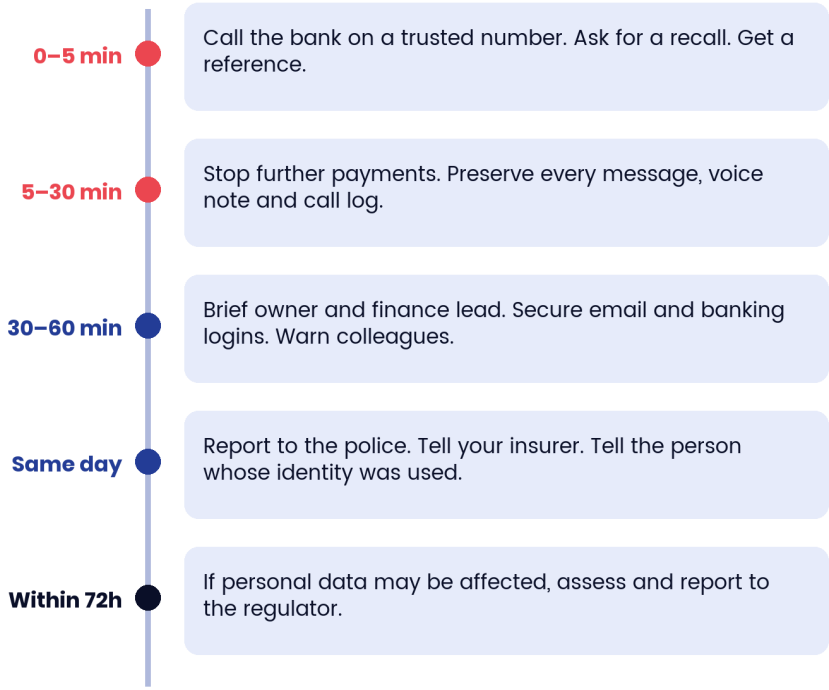
- Use strong authentication, protect account recovery and check your insurance.

CHAPTER 8

If You Think You Have Been Targeted



Perhaps a suspicious request arrived and you stopped. Perhaps you did not stop, and money has gone. Either way, speed matters. This chapter gives you a calm, ordered response.



The first hour

If money has been sent

Within minutes

1. **Call your bank immediately** using the number on your card, your bank statement or the bank's official site, not a number from any message. Tell them you have been the victim of fraud, give the payment details, and ask them to attempt to recall the payment and to contact the receiving bank. Time is the biggest factor: money is often moved on quickly.
2. **Ask for a fraud reference number** and the name of the person you spoke to.
3. **Stop further payments** to the same account or from the same process.

Within the first hour

4. **Preserve evidence.** Do not delete messages, emails, voice notes or call logs. Take screenshots, note numbers, times and details. Do not forward the message around; save copies in one place.
5. **Tell the owner or director and the finance lead.** Agree on one person to coordinate.
6. **Check whether other accounts are affected.** If a mailbox may be compromised, change its password from a clean device, revoke active sessions, and check for forwarding rules you did not set up.
7. **Warn colleagues.** The same attacker may be contacting others right now.

If credentials or data were shared

- **Change the passwords** for affected accounts from a clean device and revoke sessions. If a one-time code was read out, treat the account as compromised.
- **Remove any remote-access software** that was installed, disconnect the device from the network, and ask your IT provider to examine it.
- **Check what was exposed.** What files, customers or staff could have been affected?

Report it

- **Report the fraud to the police.** In England, Wales and Northern Ireland, fraud and cyber crime are reported through the national Report Fraud service, which replaced Action Fraud (it launched in December 2025 and the full public launch followed in January 2026); in Scotland, report to Police Scotland on 101. [4] You will get a crime reference number, which your bank and insurer may ask for.
- **Tell your insurer promptly.** Many policies have strict notification windows.

- **Tell the genuine person or supplier whose identity was used.** They may need to warn other clients, and it helps them protect their reputation.
- **Consider data-protection duties.** If personal data may have been exposed, you may need to assess the breach and, where it presents a risk to people, report it to the data-protection regulator (in the UK, the ICO) without undue delay and, where required, within 72 hours of becoming aware. [5] If you are unsure, take advice early; the clock runs from when you become aware.

Recovering and learning

After the immediate response, hold a short, blameless review:

- What was the first sign that something was unusual?
- Which control failed or did not exist?
- What single change would have stopped it?
- Who needs to be told or reassured (staff, clients, suppliers)?

Update your policy and your trusted-contact register. If a team member was fooled, support them. They are often the most distressed person in the business and the most useful witness.

> **Illustrative example: The Friday that was caught.** A small recruitment agency paid £7,400 to a changed account on a Friday afternoon. On Monday the genuine supplier chased the invoice. The office manager phoned the bank within ten minutes, the bank contacted the receiving bank, and a portion of the funds was frozen. The business then reported to the police, informed its insurer, and rewrote its policy that week. Not all the money was recovered, but speed saved part of it, and the review found the real cause: nobody was responsible for checking bank-detail changes.

A short incident card

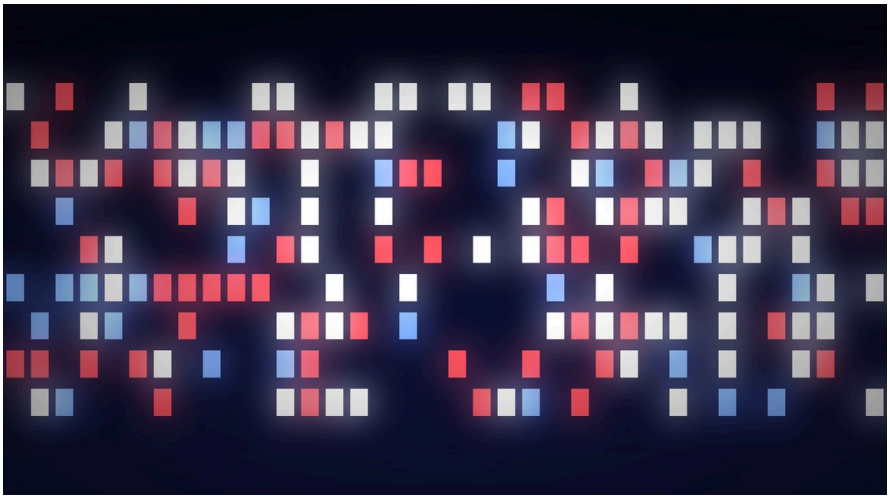
Appendix E is a one-page card with the first-hour steps. Keep it near the payments desk and in the shared drive.

Key takeaways

- Call the bank first, using a number you trust. Minutes matter.
- Preserve evidence, secure accounts and warn colleagues.
- Report to the police, your insurer and, where personal data is involved, assess your data-protection duties quickly.

CHAPTER 9

Your First Thirty Days



A plan on paper is worth nothing until it is part of how the business runs. Here is a realistic thirty-day programme for a small firm, with minimal cost.

WEEK 1 Decide and write	WEEK 2 Secure basics	WEEK 3 Register and train	WEEK 4 Test and review
☐ Say the rule aloud	☐ MFA on email and bank	☐ Trusted contact register	☐ Harmless drill
☐ Name second approver	☐ Check recovery details	☐ Call key suppliers	☐ Ask broker the question
☐ Write 1-page policy	☐ Bank dual-authorisation	☐ 30-minute team session	☐ Diary 6-month review
☐ Print checklist	☐ Domain email checks		

The thirty-day roadmap

Week 1: Decide and write

- Hold a ten-minute conversation: "Here is the rule: we verify before we pay, change bank details or share codes."
- Choose who is the **second approver** and who is the **reporting contact**.
- Write the one-page payment policy (Appendix C), including thresholds.
- Print the checklist (Appendix A) and the pause script.

Week 2: Secure the basics

- Turn on multi-factor authentication for email, banking and accounting.
- Review recovery email addresses and phone numbers on your key accounts.
- Ask your bank about dual authorisation, limits and alerts.
- Check sender-authentication settings on your domain.

Week 3: Build the register and train the team

- Create the trusted-contact register (Appendix B): directors, bank, accountant, key suppliers and IT provider.
- Phone each key supplier from a known number, confirm their bank details and note the date.
- Run a thirty-minute team session using the five scenarios in Chapter 3.

Week 4: Test and review

- Run a harmless **drill**: send a clearly labelled test request and see whether the process works (with the owner's agreement, and no one blamed).
- Ask your insurance broker the plain-language question from Chapter 7.

- Book a six-month review in the diary.

Keeping it alive

- Re-cover the key rules briefly each quarter.
- Add new starters to training in their first week.
- When you change bank, supplier, software or staff, check the register and policy.
- Share anything you learn with peers; fraud thrives on isolation.

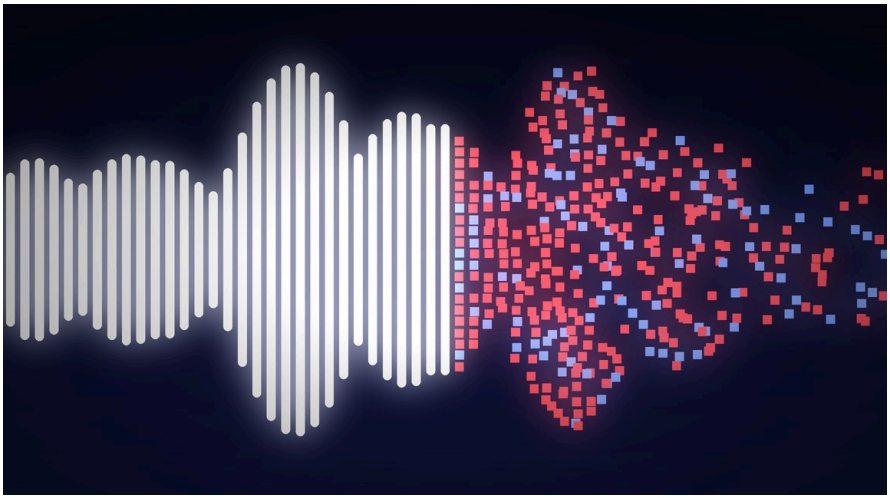
Where GDPRGard can help

If your business handles personal data, the same discipline that stops an impersonation scam helps with privacy compliance: knowing who is authorised, recording decisions and responding quickly to incidents. GDPRGard.eu offers practical, plain-English guides and tools on GDPR and data protection for small businesses, including material on breach response and records. It is one resource among several; use whichever help fits your situation.

Key takeaways

- Start small: decide, write, secure, train, test.
- Thirty days is enough to have a real procedure.
- Review regularly; fraud tactics change but the verification rule does not.

Conclusion: A Voice Is Only a Voice



Priya's story did not have to end badly. If Priya's firm had had a one-page policy, a saved list of trusted numbers and a director who had said out loud, "Check me", the call at ten to five would have been a four-minute inconvenience. The voice on the phone could have been perfect, and it would not have mattered.

That is the central lesson of this book. You cannot out-listen a machine. You can out-process it. A fraudster's most expensive asset is a convincing performance; yours is a habit of asking, calmly, for a second channel.

So start where you are. Tell your team the rule: **verify before you pay, change, or share.** Print the checklist. Build your trusted-contact register this week. Make it safe to pause, and safe to report a mistake.

The criminal needs you to act fast, act alone and act quietly. Do the opposite. Be slow, be two, be open. **Don't trust the voice. Trust the process.**

APPENDIX A

One-Page Payment Verification Checklist

Complete one for every elevated or high-risk payment or change.

Date / time: _____ **Prepared by:** _____ **Amount:** _____

Payee: _____ **Reason for payment:** _____

- ☐ **1. Stop.** Is anything unusual (new payee, new bank details, amount, urgency, channel, secrecy)?
- ☐ **2. Verify the requester.** I used a contact I already held, not one from the request.
- ☐ **3. Confirm.** Recipient, amount and purpose match our records; account details match the independently verified supplier record; name-match check passed.
- ☐ **4. Second approval** by a different authorised person who saw this record.
- ☐ **5. Recorded.** Verification note below is complete.
- ☐ **6. Release** only after every box above is ticked.

Verification note: Called _____ on _____ (number from: ☐ contract ☐ register ☐ directory) at _____. Answer: _____

Second approver: _____ **Time released:** _____

Red flags: ☐ urgency ☐ secrecy ☐ authority ☐ new number ☐ bank change ☐ codes ☐ refused callback. If you cannot complete a step: **do not pay. Tell the owner.**

APPENDIX B

Trusted Contact Register (Template)

Keep this register private. Add entries only from a trusted source, never in response to a request. Review every six months.

Who / organisation	Role	Verified number	How verified	Date	Reviewed by
Managing director	Authorises payments		In person		
Finance lead	Second approver		In person		
Bank relationship / fraud line	Recall payments		Bank website + card		
Accountant	Advice		Contract		
IT provider	Account and device issues		Contract		
Key supplier 1	Payment queries		Called from register		
Key supplier 2	Payment queries		Called from register		
Insurance broker	Claims notice		Policy documents		

Rules for the register

- Only named staff may edit it.
- Update a supplier's entry only after an independent callback.
- Never store the register in an email thread that others can edit.

APPENDIX C

Short Payment Verification Policy (Template)

Adapt to your business. This template is a starting point, not legal advice.

1. Purpose. To protect [Business name] from payment fraud, impersonation and unauthorised disclosure of information.

2. Scope. All payments, supplier or customer bank-detail changes, and requests for credentials, codes or confidential data.

3. Principle. A voice, video image, caller ID or message is not proof of identity. Requests are verified through a trusted, independent channel chosen by us.

4. Authorisation. Payments are never authorised through a call, video meeting or messaging app. They are authorised in [accounting/banking system] by the persons below.

Amount or type	Required
Up to £_____ to an existing payee	One authorised person
£_____ to £_____, or any new payee	Callback + second approver
Over £_____, or any change of bank details	Callback to a registered contact + second approver + written record + delay until complete

5. Verification. Use contact details from the Trusted Contact Register or other records held before the request. Never use details supplied in the request.

6. Prohibited actions. No one may share passwords or one-time codes, install remote-access software at another's request, or bypass this policy at any person's instruction, including a director's.

7. Emergency route. If an urgent payment is genuinely needed and the usual approver cannot be reached, [named alternate] may approve up to £_____ after independent verification, with a record.

8. Reporting. Anyone who suspects a fraud or has made a mistake must tell [name] immediately. No one will be disciplined for reporting in good faith or for pausing a request.

9. Review. This policy is reviewed every six months and after any incident.

Approved by: _____ **Date:** _____

APPENDIX D

Pause Script Card

Keep these where staff can see them.

Phone: "Thanks. I need to confirm any payment like this before it goes. I'll call you straight back on your usual number."

Video / meeting: "I can't release this on the call. It needs a second approval. I'll follow up afterwards through the normal route."

Message: "Before I act, I'm going to confirm this through our usual channel, as we do for all payment changes."

If pushed: "I understand it's urgent. This is the process for everyone. If it's genuine it will only take a few minutes."

If alone and unsure: "I'm going to check with [name] first and come back to you in ten minutes."

Always remember

- Codes are never read out.
- Remote-access tools are never installed at a caller's request.
- Secrecy is a reason to check, not to skip checking.
- You will not be blamed for pausing.

APPENDIX E

First-Hour Incident Card

If money has gone:

- ☐ Call the bank on a trusted number. Ask to recall the payment. Get a reference.
- ☐ Stop further payments to the same account.
- ☐ Preserve messages, voice notes, call logs and emails. Screenshot, do not delete.
- ☐ Tell the owner and finance lead. Name one coordinator.
- ☐ Secure email and banking logins from a clean device; check mailbox forwarding rules.
- ☐ Warn colleagues.

If codes, passwords or files were shared:

- ☐ Change passwords and revoke sessions.
- ☐ Remove remote-access software; disconnect the device; call your IT provider.
- ☐ List what data could be affected.

Then:

- ☐ Report to the police (Report Fraud in England, Wales and Northern Ireland; Police Scotland on 101).
- ☐ Tell your insurer.
- ☐ Assess personal-data breach duties (UK: the ICO; 72-hour clock from awareness, where reportable).
- ☐ Hold a blameless review within a week and update the policy.

Key numbers (fill in): Bank fraud line _____ Broker _____ IT provider _____

Sources and Further Reading

1. Reported by the *Wall Street Journal* in August 2019 and summarised by Sophos, Gizmodo and PaymentsJournal: a UK energy company's managing director transferred €220,000 after a call he believed came from his German parent company's chief executive; the insurer, Euler Hermes, declined to name the company.
2. Arup's statements to the press (May 2024) and Hong Kong police reporting (February 2024), as summarised by the *South China Morning Post* and others: an employee in Hong Kong made fifteen transfers totalling HK$200 million after a video call in which other participants were reportedly deepfakes. Arup said its internal systems were not compromised. Confirmation rests on press statements.
3. Authorised push payment (APP) fraud reimbursement rules, Payment Systems Regulator, effective for payments from 7 October 2024: per law-firm and bank summaries (Bird & Bird, Santander and others), a limit of £85,000, cover for Faster Payments and CHAPS between UK accounts, eligibility for individuals, micro-enterprises and charities, and a 13-month claim window. These were secondary summaries; check the regulator's current rules and your bank's terms.
4. City of London Police, announcements on the Report Fraud service (launched 4 December 2025; full public launch January 2026), which replaced Action Fraud for England, Wales and Northern Ireland. Police Scotland remains the route in Scotland.
5. Reporting a personal-data breach to the ICO within 72 hours of becoming aware, where the breach is likely to result in a risk to people's rights and freedoms: UK GDPR, Article 33, and ICO guidance. Stated from working knowledge and not re-read for this edition; confirm on the ICO website.

Further reading. The UK National Cyber Security Centre publishes free small-business guidance, including advice on phishing and multi-factor authentication. UK Finance's "Take Five to Stop Fraud" campaign offers short, clear advice for individuals and staff. Your bank will have its own fraud guidance for business customers.